



Welcome to Lu-GeSTA News

Were we break news like hackers break into your dad's Facebook account.

UNC2891 Breaches ATM Network via 4G Raspberry Pi, Tries CAKETAP Rootkit for Fraud.

Incident Overview – UNC2891

ATM Network Breach

- A sophisticated threat actor (also known as *LightBasin*) with a history of targeting financial institutions globally.

What Was the Objective?

- To fraudulently withdraw ATM funds by spoofing legitimate Hardware Security Module (HSM) messages used in card authorization.

How?

- By deploying a custom rootkit named **CAKETAP** designed to intercept and manipulate ATM communication with HSMs.

Why It Matters

- Demonstrates a rare mix of **physical access, custom malware, and crafty techniques**, exposing real-world vulnerabilities in banking infrastructure.

Attack Method – The Role of the Raspberry Pi



- Physically planted Raspberry Pi 4 with 4G modem into ATM network switch as a covert backdoor.
- Used mobile 4G connection to bypass bank firewalls and monitoring.
- Controlled remotely via TinyShell backdoor linked to dynamic DNS.
- Hid malicious activity using Linux bind mounts to evade detection.
- Moved laterally inside network, compromising mail server for persistent access after Pi removal.



Technical Mechanics

Malware tools and stealth techniques

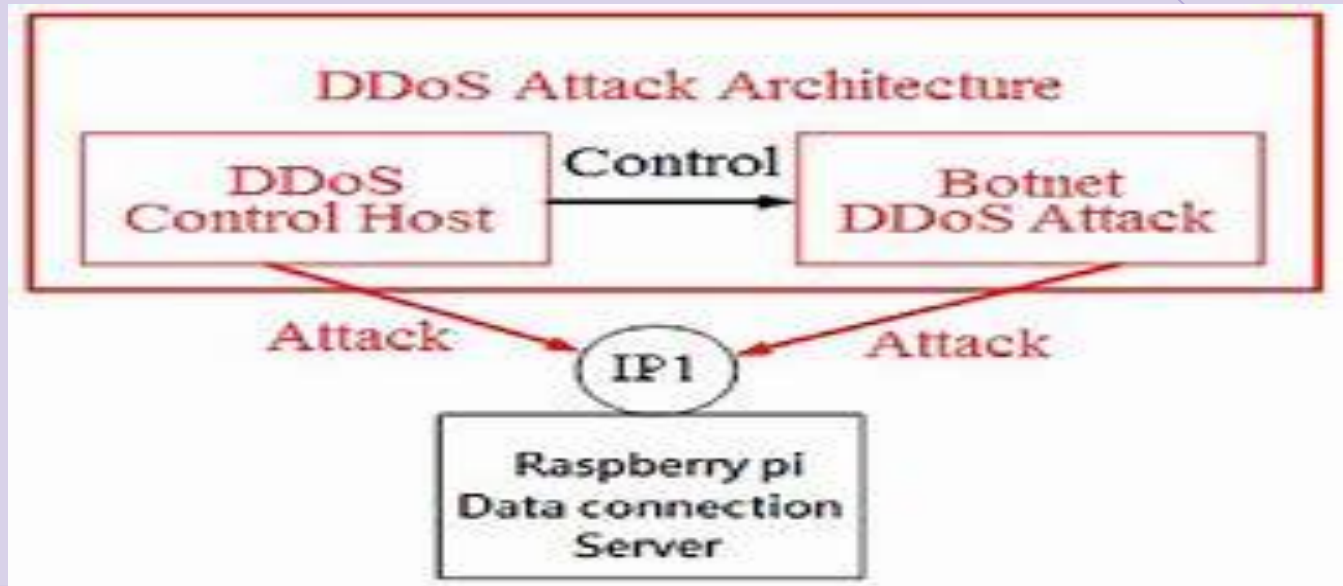
Bind-Mount Evasion

UNC2891 used Linux bind mounts to hide malicious processes.

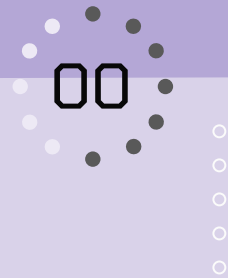


This technique evades full-scan tools and process listings.

This is a documented technique in MITRE ATT&CK as **T1564.013**.



DISGUISED MALWARE



- Deployed a rootkit named **CAKETAP** disguised as the legitimate **lightdm** system service.
- Enabled stealthy persistence and avoided detection by system admins.



Command & Control via Dynamic DNS

- Raspberry Pi used a **TINYHELL** backdoor.
- Maintained outbound C2 via **Dynamic DNS** and encrypted **HTTP proxy**.

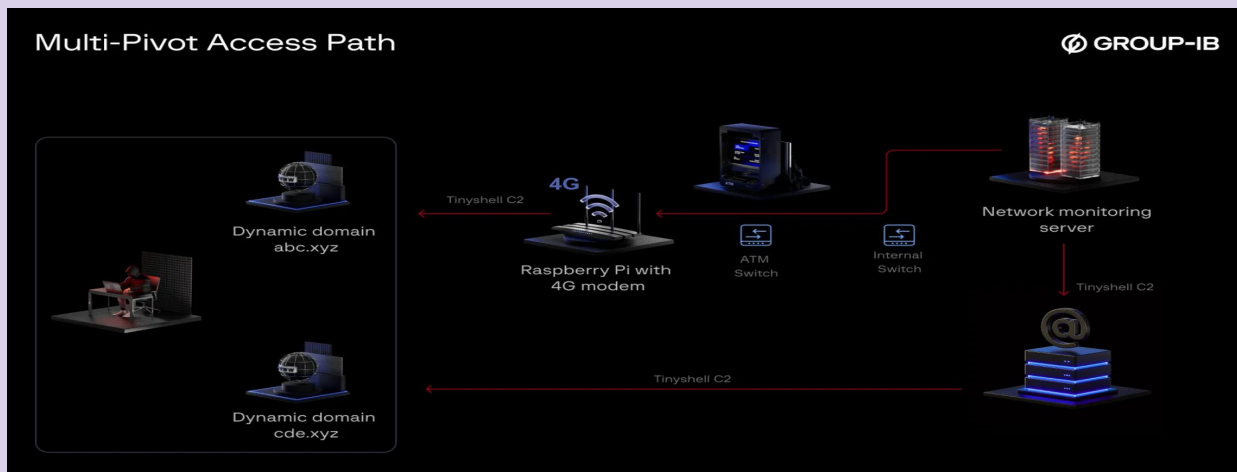


- Bypassed perimeter firewalls and traditional defenses.
- Even after the Raspberry pi was removed, access remained.
- A backdoor on the mail server continues to connect to the attacker's infrastructure.



Technical sophistication

- Attacker demonstrated deep knowledge of Linux/Unix systems.
- Combined physical access, kernel-level rootkits and covert networking.
- Campaigned disrupted before financial fraud was executed.



UNC2891 / LightBasin Strategy & Target Motives



- ● Active since 2017, targets financial institutions.
- ● Advanced in Linux, Unix, Solaris, HSMs
- ● Used malware CAKETAP rootkit
 - CAKETAP is a rootkit designed to trick the bank's HSM into approving fake ATM transactions.
- ● Bypass security, trigger fake ATM withdrawals
- ● Attack stopped before any money was stolen



How the hackers gained Access

Initial Breach:
Gaining Physical
Entry

Hired “runners”

Targeted infrastructure without raising alarms

Physical presence enabled direct manipulation of devices



Implanting the Device

Raspberry Pi
Insertion

Compact Raspberry Pi - Remote AP

Strategic placement for minimal
detection - Switch

Direct physical network access



Establishing Remote Access

Firewall Bypass via
4G Connectivity

Pi used **4G cellular connection**

Bypassed internal security
protocols and firewalls

Enabled remote communication



Attribution Challenge

*Unknown Origin &
Lack of Logs*



No visible security logs tracking device placement

No known entry point for initial deployment

Internal investigations unable to determine attacker's identity



The Good News:

In the UNC2891 case, the attackers **tried** to install CAKETAP, but the attack was **caught and stopped before any actual cash was stolen**.

The Bad News:

A failed attack still exposes dangerous gap.

**Attack neutralized before
fraudulent withdrawals occurred**



How to prevent this from happening

- Lock down access to server rooms, wiring closets, ATM hardwares. No usb or device plug in from public view.



- Use **RF detection** tools to alert on unexpected wireless devices.
 - Use tamper-evident seals and surveillance.



- Conduct regular physical inspections of critical equipment.

Lesson learned

- You can have the best firewalls in the world—but if someone can plug into your internal switch, they can bypass **EVERYTHING!**

